



Zero Trust e DevSecOps

Tópicos Avançados em TI

Aula 11/23

la

Segmentação

Container

Devops

Iac

Cloud

Zero trust

Devsecops

Conceito

Zero Trust ("nunca confie, sempre verifique") é como um porteiro que pede identificação toda vez que você entra em um prédio, mesmo já conhecendo seu rosto. Nenhum usuário ou dispositivo é confiável por padrão, mesmo dentro da rede corporativa. Princípios (NIST SP 800-207): verificar explicitamente (autenticação + autorização contínua), acesso com menos privilégio (least privilege, JIT - Just In Time), assumir violação (segmentação micro, criptografia de ponta a ponta). Tecnologias: BeyondCorp (Google), Zscaler, Cloudflare Access, Okta. DevSecOps integra segurança no ciclo de DevOps ("shift left"): análise de código estática (SAST - SonarQube, Semgrep), análise dinâmica (DAST - OWASP ZAP, Burp), análise de dependências (SCA - Dependabot, Snyk), análise de containers (Trivy, Clair, Falco), análise de IaC (Checkov, tfsec). Políticas como código: OPA (Open Policy Agent), Kyverno. Segurança em pipelines: assinatura de artefatos (Sigstore, cosign), SBOM (Software Bill of Materials).

Zero Trust

Nunca confie, sempre verifique

SAST

DAST

SCA

Shift Left Security



Atividade Prática

Implemente análise de segurança em uma pipeline: (1) crie um repositório com código contendo uma vulnerabilidade intencional (ex: SQL injection simulada), (2) adicione Semgrep ou SonarQube na pipeline GitHub Actions, (3) execute e veja a vulnerabilidade detectada, (4) corrija e confirme que passou.



Pesquisa

Pesquise o modelo Zero Trust da Google (BeyondCorp): como a Google elimina VPNs corporativas baseando acesso em identidade do usuário + dispositivo + contexto, e não na localização da rede. Compare com modelos tradicionais de segurança de perímetro (castelo + fosso).



Requisitos

Conta GitHub. Repositório para CI/CD. Semgrep: `pip install semgrep && semgrep --version`.